

Lab 1: Network Scanning with Nmap

Introduction:

L'objectif de ce TP est de comprendre les différentes phases employées par un attaquant lors de la préparation et du lancement d'une cyberattaque. Dans ce cadre, nous utiliserons Nmap, un outil de référence pour la découverte de réseau et l'audit de sécurité des hôtes.

Pour débiter ce TP, nous avons configuré nos deux machines virtuelles (VM) sur un réseau interne (Internal Network) via VirtualBox afin de garantir un environnement d'expérimentation isolé. Une fois la configuration réseau terminée, nous avons vérifié la connectivité entre les machines à l'aide de requêtes ICMP via la commande ping.

Voici les paramètres réseau identifiés :

- Machine attaquante (Kali Linux) : 192.168.56.104/24
- Cible (Metasploit) : 192.168.56.103/24

Les deux hôtes appartiennent au même sous-réseau, à savoir le réseau 192.168.56.0/24.

```
(kali@Kalilinux)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:90:9b:27 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.104/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 493sec preferred_lft 493sec
    inet6 fe80::a00:27ff:fe90:9b27/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@Kalilinux)-[~]
$ ping 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=2.28 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.671 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=3.99 ms
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.829 ms
^C
— 192.168.56.103 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3019ms
rtt min/avg/max/mdev = 0.671/1.943/3.992/1.339 ms
```

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:20:3e:8e brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
    inet6 fe80::a00:27ff:fe20:3e8e/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ ping 192.168.56.104
PING 192.168.56.104 (192.168.56.104) 56(84) bytes of data.
64 bytes from 192.168.56.104: icmp_seq=1 ttl=64 time=1.02 ms
64 bytes from 192.168.56.104: icmp_seq=2 ttl=64 time=0.988 ms
64 bytes from 192.168.56.104: icmp_seq=3 ttl=64 time=1.84 ms
64 bytes from 192.168.56.104: icmp_seq=4 ttl=64 time=1.71 ms

--- 192.168.56.104 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 0.988/1.393/1.841/0.389 ms
msfadmin@metasploitable:~$
```

Pour bien comprendre notre environnement de notre réseau on effectue plusieurs scans, On va chercher à comprendre s'il y a des appareils entre l'attaquant et la cible, que ce soit des routeurs ou switches, ou bien le nombre d'appareil sur le réseau.

La première commande utilisée est : `nmap -traceroute 192.168.56.103`, qui nous permet via le traceroute. On envoie des paquets TTL initialisés à 1, puis incrémentés à chaque saut, ainsi on peut reconstruire la liste des routeurs intermédiaires.

TRACEROUTE		
HOP	RTT	ADDRESS
1	1.74 ms	192.168.56.103

Le HOP soit le nombre de saut est à 1 donc, on n'a pas de routeur ou ni de switch entre notre host et la cible.

1. scan du réseau, on voit bien nos 2 machines sur notre réseau

```
(kali@Kalilinux)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 09:56 CET
Nmap scan report for 192.168.56.2
Host is up (0.00037s latency).
MAC Address: 0A:00:27:00:00:07 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00022s latency).
MAC Address: 08:00:27:2C:C3:D1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0012s latency).
MAC Address: 08:00:27:20:3E:8E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.104
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.27 seconds
```

Angel Velasco
Maxime Sourdin
ING4 Cyber Gr 02

2.nmap --iflist : Pour voir mes réseaux locaux connectés.

```
(kali@kalilinux)-[~]
$ nmap --iflist
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 10:10 CET
*****INTERFACES*****
DEV (SHORT) IP/MASK          TYPE      UP MTU  MAC
lo (lo)      127.0.0.1/8             loopback  up 65536
lo (lo)      ::1/128             loopback  up 65536
eth0 (eth0)   192.168.56.104/24          ethernet  up 1500 08:00:27:90:9B:27
eth0 (eth0)   fe80::a00:27ff:fe90:9b27/64 ethernet  up 1500 08:00:27:90:9B:27

*****ROUTES*****
DST/MASK          DEV  METRIC GATEWAY
192.168.56.0/24   eth0 100
::1/128           lo   0
fe80::a00:27ff:fe90:9b27/128 eth0 0
fe80::/64         eth0 1024
ff00::/8          eth0 256
```

4.1 Network Discovery

Q1. How do you determine the correct network prefix to scan? Explain your methodology.

Si on se met à la place d'un attaquant réel, pour scanner un réseau, on peut commencer par identifier les domaines associés et résoudre leurs enregistrements DNS.

L'option --system-dns permet d'interroger directement le serveur DNS de l'entreprise ciblée afin d'obtenir des informations comme les serveurs de fichiers.

Ensuite, on peut analyser le voisinage réseau avec la commande nmap --sn Network-IP, ce qui permet de repérer les hôtes actifs.

Enfin, pour comprendre la topologie du réseau, on utilise l'option --traceroute, qui révèle le chemin emprunté par les paquets.

Q2. In a real-world penetration test, how would an attacker obtain this information?

Un attaquant peut récupérer ces informations de deux manières différentes : Internet ou le réseau local.

- Depuis Internet : il peut consulter les bases de données publiques des registres IP comme WHOIS, ou utiliser des moteurs de recherche spécialisés tels que Shodan pour identifier les services exposés.
- Depuis un réseau local : il peut obtenir les informations réseau grâce à des commandes comme ipconfig ou ifconfig, qui révèlent la configuration de l'interface et le préfixe réseau.

Q3. What is the technical term for this reconnaissance phase?

Cette phase est appelée Footprinting.

Elle peut être passive (sans interaction directe avec la cible) ou active (en envoyant des paquets, par exemple via des requêtes Ping).

4.2 Host Discovery

Q4. What type of scan does Nmap use by default for host discovery?

Sur un réseau local, Nmap utilise principalement des requêtes ARP pour identifier les hôtes actifs. Sur un réseau distant, il envoie des requêtes ICMP (ping) ou des paquets TCP pour détecter les machines accessibles.

Q5. What are the differences between SYN scan, TCP connect scan, and UDP scan?

Avec la commande SYN Scan -sS on envoie un SYN, on reçoit un SYN/ACK. puis on envoie un RST pour couper.

```
(kali@Kalilinux)-[~] 00:17 CET
$ nmap -sS 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 11:12 CET
Nmap scan report for 192.168.56.103
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
```

Avec la commande TCP Connect (-sT), c'est plus lent, on effectue la connexion TCP complète.

```
(kali@kalilinux)-[~]
$ nmap -sT 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 11:13 CET
Nmap scan report for 192.168.56.103
Host is up (0.0053s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
```

Avec la commande UDP Scan (-sU), c'est encore plus lent car il n'y a pas d'accusé de réception.

Ces trois types de scans permettent d'obtenir une vision complémentaire de l'état des ports : le SYN scan offre une approche rapide, le TCP connect fournit une analyse complète mais plus visible, tandis que le scan UDP permet d'identifier les services non-TCP malgré sa lenteur. Ensemble, ils permettent une cartographie plus fiable d'un système.

Q6. How can you make a scan stealthier and more difficult to detect?

- Pour ralentir le débit on utilise les option -T0 ou -T1 pour espacer l'envoi des packets
- Utiliser des leurres avec l'option -D qui permet d'envoyer des packets avec de fausses adresses ip en plus de la notre pour noyer les logs du défenseur
- Une autre technique est de changer l'adresse MAC: avec --spoof-mac pour masquer l'identité du fabricant de notre carte réseau

4.3 Service Enumeration

Q7. What services are running on the target machine? List all discovered services with their port numbers.

En exécutant la commande -sV sur l'ip cible on observe des services utilisés comme ssh http ou bien ftp. Dans le cadre d'une attaque cela peut être utile pour cartographier la surface d'attaque ou la recherche d'exploits spécifiques.

```
(kali@Kalilinux)-[~]
$ nmap -sV 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-09 11:22 CET
Nmap scan report for 192.168.56.103
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
```

Q8. What is this enumeration phase called in penetration testing methodology?

On appelle cette étape la phase de scanning pour connaître les machines qui sont allumées dans un réseau.

On peut classer ces phases comme suit :

- Reconnaissance (Footprinting) : "Je cherche l'adresse de l'entreprise."
- Scanning (Découverte d'hôtes) : "Je cherche quelles machines sont allumées dans le bâtiment."
- Énumération : "Je regarde par quelles portes (ports) je peux entrer et je demande précisément qui garde chaque porte (services et versions)."
- Analyse de vulnérabilités : "Je vérifie si ces gardiens ont des faiblesses connues."

Q9. How does Nmap determine which services are running on each port?

La capture de bannière

Dès que Nmap trouve un port ouvert, il s'y connecte et "écoute". De nombreux services (comme SSH, FTP ou Telnet) envoient automatiquement une ligne de texte pour s'identifier dès la connexion.

Exemple : Le port 22 envoie immédiatement SSH-2.0-OpenSSH 8.9p1. Nmap sait alors instantanément quel est le service et sa version.

Angel Velasco
Maxime Sourdin
ING4 Cyber Gr 02
L'envoi de sondes actives

Si le service reste muet (comme un serveur Web qui attend une requête), Nmap consulte sa base de données nmap-service-probes. Il envoie alors des requêtes spécifiques (une requête HTTP GET, une demande de session SMB, etc.) pour forcer le service à répondre.

La correspondance de signatures

Nmap analyse la réponse reçue et la compare à des milliers de signatures stockées dans ses fichiers.

- Le principe : Même si un serveur de base de données MySQL tourne sur le port 80 (habituellement réservé au Web), Nmap reconnaîtra la structure de la réponse propre à MySQL et l'identifier correctement.

4.4 Operating System Detection

Q10. Identify the operating system running on the target machine. What Nmap flag did you use?

Pour identifier l'OS de la machine cible on utilise la commande nmap -O.

```
(kali@kalilinux)-[~]  
$ nmap -O 192.168.56.103 | grep OS  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

On observe :

- Système d'exploitation identifié : La machine cible exécute Linux (une version du noyau Linux 2.6.X).
- Détails supplémentaires : Nmap précise qu'il s'agit probablement d'une version située entre Linux 2.6.9 et 2.6.33.
- Flag Nmap utilisé : Vous avez utilisé le flag -O.

On peut le voir clairement en haut de votre commande : nmap -O 192.168.56.103.

Notre cible est une machine extrêmement vulnérable , car elle possède un nombre élevé de services critiques ouverts :

- Services de gestion à distance non sécurisés : Telnet (23), Rlogin (513), Shell (514).
- Bases de données : MySQL (3306), PostgreSQL (5432).
- Partages de fichiers : FTP (21), NFS (2049), Samba/SMB (139/445).

Angel Velasco
Maxime Sourdin
ING4 Cyber Gr 02

```
└─$ nmap -O 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-16 09:30 CET
Nmap scan report for 192.168.56.103
Host is up (0.00080s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```


4.5 Firewall Detection

Q11. Determine if there is a firewall filtering traffic. What evidence supports your conclusion?

On a vu en commençant le Lab que grâce à la commande –tracroute on obtient un saut de 1, donc il n'y a aucun appareil qui sépare la VM attaquante que la cible.

```
Nmap scan report for 192.168.56.103
Host is up (0.00056s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:20:3E:8E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

TRACEROUTE
HOP RTT      ADDRESS
1   0.56 ms  192.168.56.103
```

Oui, il y a un pare-feu si on observe des ports marqués comme filtered ou si le traceroute s'arrête brusquement avant la cible tout en permettant la communication sur certains ports spécifiques (comme le port 80 ou 443).

4.6 Vulnerability Research

Q12. Research and document a vulnerability in the FTP server running on this machine.

Avec la command -sV -p 21 on spécifie le nom du port que l'on veut scanner pour connaître sa version, ftp 2.3.4

```
(kali@Kalilinux)-[~]
$ nmap -sV -p 21 192.168.56.103/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 10:21 CET
Nmap scan report for 192.168.56.2
Host is up (0.00088s latency).

PORT      STATE      SERVICE VERSION
21/tcp    filtered  ftp
MAC Address: 0A:00:27:00:00:06 (Unknown)

Nmap scan report for 192.168.56.100
Host is up (0.00024s latency).

PORT      STATE      SERVICE VERSION
21/tcp    filtered  ftp
MAC Address: 08:00:27:68:79:BF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.103
Host is up (0.00054s latency).

PORT      STATE      SERVICE VERSION
21/tcp    open      ftp      vsftpd 2.3.4
MAC Address: 08:00:27:20:3E:8E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
```

Vulnérabilité:

identifiant : CVE-2011-2523.

Description : Une version du code source de vsftpd a été compromise et une "porte dérobée" (backdoor) y a été insérée. Si un utilisateur se connecte avec un identifiant se terminant par un smiley :) (ex: user :)), le serveur ouvre un shell de commande sur le port 6200.

Q13. What type of vulnerability is this (e.g., buffer overflow, authentication bypass)?

Il s'agit d'une vulnérabilité de type backdoor.

Elle permet une exécution de code à distance avec les privilèges "root".

Q14. Search for and document any additional vulnerabilities present on this VM.

Selon les services qu'on a identifié lors de notre scan de ports, voici les vulnérabilités les plus courantes sur la VM cible :

Service	Port	Vulnérabilité potentielle	Description
Samba	139/445	CVE-2007-2447 (Username map script)	Permet l'exécution de commandes arbitraires via une faille dans le script de mapping des utilisateurs.
Java RMI	1099	Unauthenticated RCE	Le registre RMI permet de charger des classes distantes sans authentification, menant à une prise de contrôle totale.
UnrealIRCd	6667	Backdoor (CVE-2010-2075)	Similaire à vsftpd, une version du serveur IRC contenait une backdoor déclenchée par l'envoi du mot "AB".
SSH	22	Brute Force / Weak Credentials	Ces VMs Metasploit utilisent des identifiants par défaut (ex: msfadmin:msfadmin).